

SIMATS ENGINEERING ASSESSMENT TOOL 2

Name	Abinesh M
Register Number	192465050
Date	05-07-2026
Time	1 Hour

COURSE NAME: Cybersecurity Incident Handling And Response

COURSE CODE: CSA6001

COURSE OUTCOME COVERED

CO2: *Analyze incident response preparation strategies through examination of team roles, policies, SOPs, risk management practices, along with compliance frameworks to ensure organizational readiness. (BL3, BL6)*

Activity Tool : Risk Assessment and Business Continuity Case Study (Medium)

Assessment Tool Weightage: 20%

Code of Conduct:

I Abinesh M 192465050 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

Abinesh M
192465050

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Incident Response Team Planning	20%	Clearly identifies all key Incident Response Team (IRT) roles, responsibilities, reporting structure, interdepartmental coordination, and escalation procedures.	Identifies most IRT roles and responsibilities with minor omissions and reasonable coordination among departments.	Identifies only some team roles with limited understanding of responsibilities and coordination.	Unable to identify appropriate team roles, responsibilities, or organizational structure.
Incident Handling Policy, SOPs, and Communication Framework	25%	Develops a comprehensive Incident Handling Policy and SOP covering incident reporting, classification, escalation matrix, communication channels, containment, eradication, recovery, documentation, and post-incident review.	SOP and policy include most required phases with minor omissions or sequencing errors; communication process is mostly clear.	SOP covers only basic response steps with several missing policy elements or unclear communication flow.	SOP and policy are incomplete, incorrect, or lack logical incident handling procedures.
Security Governance, Awareness, and Resource Readiness	20%	Presents well-defined security policies, governance framework, awareness and training program, resource planning, readiness assessment, and effective use of SIEM/ticketing systems with clear justification.	Includes relevant governance practices, awareness activities, and resource planning with minor gaps.	Provides limited governance practices or awareness measures with insufficient explanation and incomplete readiness planning.	Fails to identify appropriate governance practices, awareness programs, or organizational readiness requirements.
Risk Assessment, Asset Criticality, BCP, and DRP	20%	Accurately identifies critical assets, evaluates threats and vulnerabilities, performs comprehensive risk assessment, prioritizes assets, and proposes effective BCP and DRP strategies with realistic recommendations.	Performs basic risk assessment, identifies major assets, and explains BCP/DRP with minor omissions.	Partial risk assessment with limited asset analysis and incomplete understanding of BCP and DRP concepts.	Unable to perform meaningful risk assessment or explain asset criticality, BCP, or DRP.
Documentation, Analysis, and Presentation	15%	Documentation is well-organized, professionally formatted, supported with diagrams/tables/flowcharts where appropriate, and communicates ideas clearly with logical analysis and conclusions.	Documentation is organized and understandable with minor formatting or clarity issues.	Documentation is partially organized with several presentation, formatting, or analytical weaknesses.	Documentation is poorly organized, incomplete, lacks supporting evidence, and is difficult to understand.

Cybersecurity Incident Handling and Response

CO2 AT2 REPORT

Student: Abinesh M

Register Number: 192465050

Course Code: CSA6001

Course Name: Cybersecurity Incident Handling and Response

Assessment: CO2 AT2

1. Resource Planning & Readiness

Overview

Resource planning ensures that an organization has the right people, technology and budget in place before a cyber incident occurs. Without adequate planning, even well-designed detection tools fail to deliver value because there is no trained staff or defined process to act on the alerts they generate. Readiness assessments reveal weaknesses in processes, monitoring and communication so that improvements can be prioritized based on actual risk rather than assumption.

A mature organization treats incident readiness as a continuous program rather than a one-time project. This means periodically revisiting the incident response plan, testing it against realistic scenarios, and updating it as the threat landscape, business systems and regulatory obligations change. Organizations that invest early in readiness typically respond faster, reduce downtime and protect business operations more effectively than those that only build capability reactively after a breach has already occurred.

Key Points

- Review existing security policies and incident response plan.
- Perform vulnerability assessment and penetration testing.
- Identify security gaps using audits and tabletop exercises.
- Evaluate employee awareness through phishing simulations.
- Assess compliance with NIST SP 800-61 and ISO/IEC 27035.
- Maintain an updated asset inventory to know what needs protecting.
- Define clear roles and escalation paths before an incident occurs.

Aspect	Details
Benefit	Improves detection, coordination and faster recovery.
Challenges	Budget, skilled workforce and integration complexity.
Recommendation	Regular drills, monitoring and continuous improvement.

2. Human, Technical & Financial Resources

Overview

Successful incident response depends on balanced investment across three resource categories: people, technology and operational funding. Skilled analysts require reliable tools to do their jobs effectively, while management must ensure continuous training, tool maintenance and licensing renewal so capability does not

degrade over time. Underinvesting in any one category creates a bottleneck that limits the effectiveness of the other two.

Human resources form the core of any response capability, since automated tools can flag anomalies but cannot yet make the nuanced judgment calls required during containment, eradication and recovery. Technical resources provide visibility and control across the environment, while financial resources sustain the program by funding training, tool renewal, third-party retainers and cyber insurance that reduces the financial impact of a major incident.

Key Points

- SOC Analysts, Incident Responders, Digital Forensics Experts.
- SIEM, EDR, IDS/IPS, Firewalls, Threat Intelligence platforms.
- Secure backup servers and disaster recovery infrastructure.
- Training budget, software licensing and cyber insurance.
- Third-party retainers for specialized forensic or legal support.
- Dedicated incident response war-room facilities and secure communication channels.

Aspect	Details
Benefit	Improves detection, coordination and faster recovery.
Challenges	Budget, skilled workforce and integration complexity.
Recommendation	Regular drills, monitoring and continuous improvement.

3. SIEM & Ticketing Systems

Overview

SIEM (Security Information and Event Management) platforms improve visibility by collecting logs from servers, cloud platforms, network devices and endpoints into a single correlated view. This centralization allows analysts to detect patterns that would be invisible when reviewing individual log sources in isolation, such as a single account authenticating from multiple geographies within a short time window.

Ticketing systems complement SIEM platforms by transforming raw alerts into structured investigations, making collaboration and accountability much easier across a distributed SOC team. Each alert becomes a trackable case with an owner, a timeline and an audit trail, which is essential both for coordinating a multi-analyst response and for demonstrating compliance during post-incident review or regulatory audit.

Key Points

- Centralized log collection from servers, endpoints and cloud services.
- Real-time event correlation to detect complex, multi-stage attacks.
- Alert prioritization based on severity and business impact.
- Incident assignment and SLA tracking for accountable response.
- Evidence documentation and reporting for audits and legal proceedings.
- Integration with SOAR playbooks to automate repetitive response actions.

Aspect	Details
Benefit	Improves detection, coordination and faster recovery.
Challenges	Budget, skilled workforce and integration complexity.
Recommendation	Regular drills, monitoring and continuous improvement.

4. Healthcare Ransomware Case Study

Overview

A ransomware attack on a hospital can delay patient care and disrupt critical operations, making healthcare one of the highest-stakes environments for incident response. Unlike a typical enterprise breach, downtime in a hospital setting can directly endanger patient safety, which changes the priority order of the response: restoring life-critical systems takes precedence even over full forensic certainty.

Asset prioritization ensures that life-saving systems, such as ventilators, infusion pumps and emergency department workstations, are restored first while forensic investigation of the ransomware's entry point and lateral movement continues in parallel. This requires a pre-established asset criticality list, since attempting to classify systems for the first time during an active incident wastes valuable response time.

Key Points

- Identify EHR databases and patient records as top-priority assets.
- Prioritize diagnostic systems and connected medical devices.
- Isolate infected machines to stop lateral spread of the ransomware.
- Validate clean offline backups before beginning any restoration.
- Restore services in order of business and patient-safety impact.
- Notify regulators and affected patients in line with breach-notification laws.

Aspect	Details
Benefit	Improves detection, coordination and faster recovery.
Challenges	Budget, skilled workforce and integration complexity.
Recommendation	Regular drills, monitoring and continuous improvement.

5. Risk Assessment, BCP & DRP

Overview

Business Continuity Planning (BCP) keeps essential healthcare services operational during an incident, whereas Disaster Recovery Planning (DRP) focuses on restoring IT systems and data after containment. Together they reduce downtime and improve organizational resilience by ensuring that both the clinical/business side and the technical side of recovery are addressed in a coordinated manner rather than in isolation.

Risk assessment underpins both plans by classifying threats according to likelihood and impact, which allows an organization to allocate limited resources to the risks that matter most. A well-structured BCP ensures patient care or business operations can continue, even in a degraded manual mode, while the DRP works in parallel to bring digital infrastructure back online safely and verifiably.

Key Points

- Classify risks as High, Medium and Low based on likelihood and impact.
- Apply MFA, network segmentation and patch management as preventive controls.
- Maintain offline, immutable backups resistant to ransomware encryption.
- Use Business Continuity Planning to keep essential services running.
- Use Disaster Recovery Planning to restore infrastructure methodically.
- Conduct regular BCP/DRP tabletop exercises to validate recovery time objectives.

Aspect	Details
Benefit	Improves detection, coordination and faster recovery.
Challenges	Budget, skilled workforce and integration complexity.
Recommendation	Regular drills, monitoring and continuous improvement.

6. Security Awareness and Training Program

Scenario

A company has noticed an increase in phishing attacks because employees frequently click malicious email links. As a cybersecurity consultant, this section designs a Security Awareness and Training Program intended to reduce such incidents by addressing the human element of the organization's attack surface, which is consistently the most exploited entry point in real-world breaches.

Overview

Phishing succeeds because it targets human decision-making rather than technical vulnerabilities, making it resistant to purely technical controls. A well-designed awareness program shifts employees from being the weakest link in the security chain to becoming an active human sensor network that reports suspicious activity before it escalates into a full incident. This requires more than an annual slideshow; it requires ongoing reinforcement, measurable objectives and visible leadership support.

The program below is structured around four pillars: targeted training content, clearly defined employee responsibilities, recurring awareness activities, and a measurement framework that allows the organization to demonstrate real reduction in risk over time rather than simply confirming that training was delivered.

Training Topics

- Recognizing phishing indicators: spoofed domains, urgency language, mismatched sender addresses.
- Safe handling of email attachments and links, including hover-to-verify techniques.
- Business Email Compromise (BEC) and CEO-fraud recognition for finance and HR staff.
- Password hygiene, multi-factor authentication and credential reuse risks.
- Safe use of removable media, personal devices and public Wi-Fi.
- Social engineering beyond email: vishing (voice phishing) and smishing (SMS phishing).
- Data classification basics so employees know what information is sensitive.
- Incident reporting procedure: who to contact and how quickly to act.

Employee Responsibilities

- Verify sender identity before clicking links or opening attachments from unknown sources.
- Report suspicious emails immediately using the designated phishing-report button or mailbox.
- Never share credentials, OTPs or sensitive data in response to unsolicited requests.
- Complete assigned training modules and simulated phishing exercises on schedule.
- Escalate any accidental click or credential entry immediately rather than concealing it.
- Keep devices patched and avoid installing unauthorized software.

Awareness Activities

- Monthly simulated phishing campaigns with varying difficulty and attack styles.
- Quarterly instructor-led or video-based refresher training tied to current threat trends.
- Cybersecurity awareness posters, intranet banners and email newsletters.
- Gamified leaderboards recognizing teams with the lowest click rates.
- Lunch-and-learn sessions featuring real (anonymized) incident case studies.
- New-hire onboarding module covering baseline security expectations.

Evaluating Program Effectiveness

Effectiveness must be measured quantitatively rather than assumed. Key metrics include the phishing simulation click-through rate over time, the percentage of employees who report simulated phishing emails instead of clicking them, the average time-to-report for suspicious messages, and the completion rate of assigned training modules. A downward trend in click rate combined with an upward trend in reporting rate indicates the program is successfully changing behavior rather than just raising awareness superficially.

- Track click-rate and report-rate trends across successive simulation campaigns.
- Measure time-to-report for both simulated and real phishing incidents.
- Conduct post-incident reviews to assess whether training gaps contributed to a breach.
- Survey employee confidence and knowledge retention periodically.
- Benchmark results against industry averages to contextualize progress.

Aspect	Details
Benefit	Improves detection, coordination and faster recovery.
Challenges	Budget, skilled workforce and integration complexity.
Recommendation	Regular drills, monitoring and continuous improvement.

7. Incident Handling Policy Framework

Scenario

A financial institution wants to standardize its cybersecurity incident response process across all branches. As a cybersecurity consultant, this section designs an Incident Handling Policy Framework that defines incident categories, reporting procedures, response phases, documentation requirements and post-incident review activities, ensuring every branch responds consistently regardless of local staffing or maturity.

Overview

Financial institutions operate under strict regulatory obligations and face a high volume of targeted attacks, making standardization essential. Without a common framework, branches may classify the same type of incident differently, escalate at inconsistent speeds, or fail to preserve evidence in a way that supports regulatory reporting or law enforcement cooperation. A centralized policy framework, applied uniformly, closes these gaps and enables the institution to respond with the same discipline whether an incident originates at headquarters or a small branch office.

Incident Categories

Incidents are classified to ensure the response team applies appropriate urgency and resourcing. A tiered classification scheme also supports consistent metrics reporting to regulators such as central banking authorities.

- Category 1 – Critical: core banking system compromise, ransomware, large-scale data breach.
- Category 2 – High: unauthorized access to customer accounts, payment fraud, DDoS affecting services.
- Category 3 – Medium: malware on a single workstation, phishing with no confirmed compromise.
- Category 4 – Low: policy violations, minor misconfigurations with no exploitation evidence.

Reporting Procedures

- Any employee who suspects an incident must report it to the branch IT contact or SOC hotline within 15 minutes of detection.
- The receiving contact logs the report in the central ticketing system and assigns an initial severity category.
- Category 1 and 2 incidents trigger immediate escalation to the central Incident Response Team (IRT) and CISO office.
- Regulatory notification timelines are tracked separately to ensure compliance with statutory breach-reporting deadlines.

Response Phases

The framework follows the widely recognized incident response lifecycle, adapted for a multi-branch banking environment where centralized coordination must work alongside local execution.

- Preparation: maintain playbooks, trained staff and tested tools at every branch.
- Identification: confirm and classify the incident, capturing initial indicators of compromise.
- Containment: isolate affected systems or accounts using short-term and long-term containment steps.
- Eradication: remove malware, close exploited vulnerabilities, and revoke compromised credentials.
- Recovery: restore systems from verified clean backups and monitor closely for recurrence.
- Lessons Learned: conduct a formal post-incident review within a defined number of business days.

Documentation Requirements

- Maintain a chronological incident timeline capturing every action taken and by whom.

- Preserve forensic evidence, including logs, disk images and network captures, with chain-of-custody records.
- Record all customer and financial impact for regulatory and internal risk reporting.
- Retain incident records in accordance with regulatory retention requirements.
- Standardize documentation templates across branches to enable consistent central analysis.

Post-Incident Review Activities

- Conduct a formal after-action review involving all stakeholders who participated in the response.
- Identify root cause and evaluate whether existing controls could have prevented or reduced the impact.
- Update playbooks, training and technical controls based on identified gaps.
- Share sanitized lessons-learned summaries across all branches to raise institution-wide maturity.
- Track remediation action items to closure with assigned owners and deadlines.

Aspect	Details
Benefit	Improves detection, coordination and faster recovery.
Challenges	Budget, skilled workforce and integration complexity.
Recommendation	Regular drills, monitoring and continuous improvement.